

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

JWT Tampering Attempt Rejected Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	JWT attack attempt
Result Type	Attack rejected / control validated
Evidence Report File	08-jwt-attack-attempt-token-rejected-evidence-report.pdf
Testing Phase	JWT Tampering and Control Validation
Tool / Component	Postman / JWT Manipulation Test
OWASP / Security Mapping	API2:2023 Broken Authentication
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

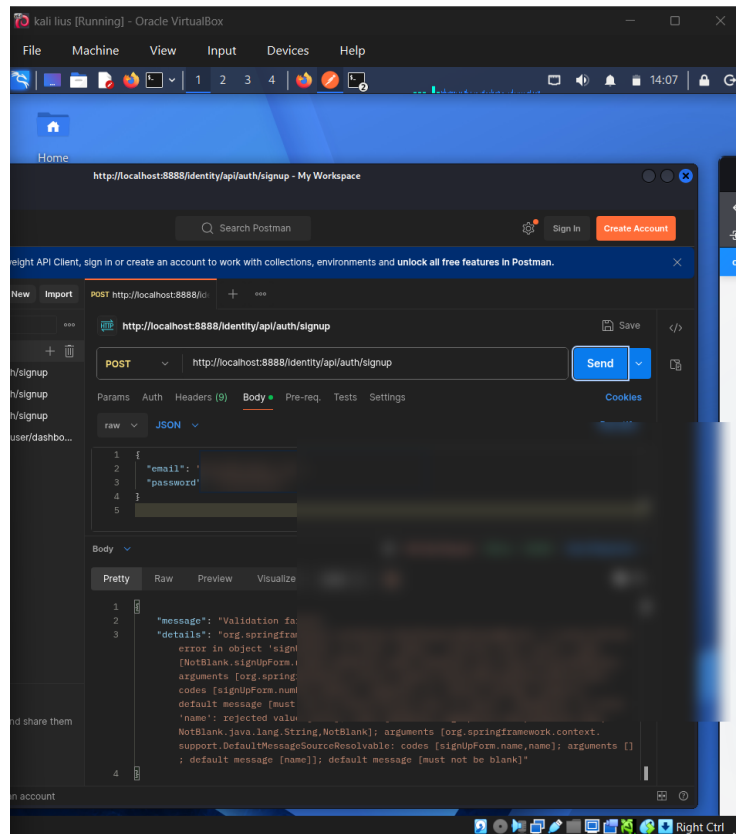


Figure 1 - Embedded screenshot evidence for: JWT attack attempt

What this evidence proves

The evidence shows an attempted token manipulation or invalid token submission being rejected. This is valuable because it validates a security control rather than confirming a vulnerability.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	JWT Tampering and Control Validation
Tool / Component	Postman / JWT Manipulation Test
Assessment Objective	Test whether the server accepts a modified JWT, changed claims, or an invalid token after tampering.
Result Type	Attack rejected / control validated
OWASP / Security Mapping	API2:2023 Broken Authentication

Why this evidence matters

A professional API report should document both successful findings and rejected attack attempts. Rejection indicates that the API is performing at least some form of token validation.

Command / workflow used

```
Decode token
Modify claim such as role or user identifier
Re-encode / submit modified token
Observe server response
Document rejection as a control validation
```

Sanitized output style

```
Request with modified token: <REDACTED>
Expected secure response: 401 Unauthorized / 403 Forbidden / invalid token error
Observed: rejected / not accepted
```

3. Professional Interpretation

This evidence row should be interpreted as: **Attack rejected / control validated**.

If the server had accepted the modified token, the impact could include privilege escalation or impersonation. Since it was rejected, this evidence supports that token validation controls are working for this test case.

Assessor notes

This should be labeled as control validated, not as a confirmed vulnerability.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Important reporting distinction

This row should not be exaggerated as a vulnerability. The correct professional wording is that the attack attempt was performed and the application rejected it, which validates a security control for this specific test case.

4. Risk, Impact, and Remediation Guidance

Risk perspective

If the server had accepted the modified token, the impact could include privilege escalation or impersonation. Since it was rejected, this evidence supports that token validation controls are working for this test case.

Recommended remediation / hardening actions

- Continue verifying signatures on every request.
- Reject unsigned or modified tokens.
- Monitor repeated invalid token attempts.
- Use strong secrets and rotation.
- Keep clear error messages without leaking validation internals.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Original token.
- Modified token.
- Authorization header.
- User and role claims.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

`[JWT attack attempt](./reports/evidence/08-jwt-attack-attempt-token-rejected-evidence-report.pdf)`

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.